

Existing System Comparison

Standalone extract of the Phase 1 report

CSE 347/652 | DES 306/525 Usable Security and Privacy
IIIT-Delhi · Monsoon 2026 · Instructor: Dr. Arun Balaji Buduru

Phase 1: User Studies to evolve Requirements, Design and Workflows
Submission: 4 October 2026

Team: [INSERT TEAM MEMBER NAMES AND ROLL NUMBERS]

Primary research status: instruments complete; fieldwork data not yet collected. All placeholders are marked [DATA REQUIRED]. No primary data has been fabricated.

14. Existing System Comparison

For each system class, the questions required by the project brief are answered from cited sources. Where a property is not publicly documented, the cell says "not documented" rather than guessing.

Property	Printed photo ID (current campus)	MIFARE Classic campus/transit card [4, 5]	Hotel keycard (VingCard Vision / Saflok) [8, 9]	US university mobile ID in Apple Wallet [35]	PIV card in federal facility access [2]
Technology	Print + laminate	13.56 MHz, CRYPTO1	13.56 MHz MIFARE Classic	NFC card emulation, Secure Element	ISO 14443 smart card, PKI certificates
What is authenticated	Card appearance vs guard's expectation; face vs printed photo	Card sector keys (broken)	Card data / derived key (broken)	Device-held credential; phone unlock	Card private key via challenge-response; optional PIN, biometric
What is authorized	Implicit: any current-looking card	Whatever the reader is configured for; typically UID/sector data mapped to permissions	Room + validity window encoded on card	Doors/services configured by the campus card system	Area-specific rules per SP 800-116; revocation checked
Information stored	On card face: photo, name, roll no., programme, validity	UID + sector data; often a student number	Room number, dates, sometimes guest data on card	Identity token; personal data on campus server; not documented in detail	Certificates, CHUID, photo, fingerprints (on card, PIN-protected)
What the user does	Show card	Tap	Tap / insert	Hold phone near reader (Express Mode: no unlock)	Insert or tap; enter PIN for higher assurance
What security staff sees	Card and face	Usually nothing; door opens or not	Nothing; lock opens	Not documented; typically door opens	Depends on PACS; may show photo
Issuance	ID cell at admission	Card office encodes	Front desk encodes at check-in	Student enrolls via campus app after login	Identity proofing per SP 800-63A; card personalisation
Revocation	Replacement issued; old card not blocked	Depends on backend; Classic UID can be blocklisted but forged cards may spoof	New card overrides old at lock (sequence number); forged cards bypass	Remote revoke via wallet and campus system	Certificate revocation lists / status checks
Security limitations	Forgery, borrowing, no revocation, no audit	Full key recovery and cloning [4, 5]	Master key derivation from one card [8]; forged card pair opens property [9]	Relay; device compromise; not independently documented	Relay; PIN shoulder-surfing; complexity
Privacy considerations	Roll number and programme visible to anyone	Fixed UID trackable	Guest data on card in some deployments	Platform (Apple) sees usage metadata? not documented	Card contains biometrics; PIN-protected
Usability considerations	Fast glance; must retrieve card	Fast tap	Fast tap	No unlock needed with Express Mode; requires compatible device	PIN entry slows; card must be carried

Take-aways for our design

1. Every documented failure involved authenticating data on the card rather than proving possession of a key the card never reveals. → SEC-01, SEC-04, D1.
2. None of the broken systems checked revocation status at the point of entry in a way a forged card could not bypass. → SEC-02, FR-03, offline signed revocation list (Section 27).
3. Successful modern deployments (PIV, mobile ID) pair a cryptographic credential with a policy engine and revocation, and, where risk warrants, a human or second factor. → Architecture in Section 28.
4. Showing the guard the photo from the server for the authenticated credential, rather than the photo printed on the card, breaks the forgery path: an attacker cannot change the server's photo by altering the card. → PRIV-03, screen 5.

42. References

Numbering is fixed; all in-text citations use these numbers.

Standards and government sources

- [1] NIST. SP 800-63-4: Digital Identity Guidelines (with 800-63A-4 Identity Proofing, 800-63B-4 Authentication and Authenticator Management, 800-63C-4 Federation). National Institute of Standards and Technology, July 2025. <https://csrc.nist.gov/pubs/sp/800/63/4/final>
- [2] NIST. SP 800-116 Rev. 1: Guidelines for the Use of PIV Credentials in Facility Access. National Institute of Standards and Technology, June 2018. <https://csrc.nist.gov/pubs/sp/800/116/r1/final>
- [3] NIST. SP 800-57 Part 1 Rev. 5: Recommendation for Key Management. National Institute of Standards and Technology, May 2020.
- [4] F. D. Garcia, G. de Koning Gans, R. Muijters, P. van Rossum, R. Verdult, R. Wichers Schreur, B. Jacobs. "Dismantling MIFARE Classic." ESORICS 2008, LNCS 5283, Springer, pp. 97–114.
- [5] K. Nohl, D. Evans, Starbug, H. Plötz. "Reverse-Engineering a Cryptographic RFID Tag." USENIX Security Symposium 2008, pp. 185–193.
- [6] F. D. Garcia, G. de Koning Gans, R. Verdult, M. Meriac. "Dismantling iClass and iClass Elite." ESORICS 2012, LNCS 7459, Springer, pp. 697–715.
- [7] D. Oswald, C. Paar. "Breaking Mifare DESFire MF3ICD40: Power Analysis and Templates in the Real World." CHES 2011, LNCS 6917, Springer, pp. 207–222.
- [8] T. Tuominen, T. Hirvonen. "Ghost in the Locks" (Vision by VingCard vulnerability disclosure). F-Secure, April 2018. Reported in: A. Greenberg, "A One-Minute Attack Let Hackers Spoof Hotel Master Keys," Wired, 25 Apr 2018.
- [9] L. Wouters, I. Carroll, et al. "Unsaflok: Security vulnerabilities in dormakaba Saflok hotel locks." Disclosure site, March 2024. <https://unsaflok.com/>. Reported in Ars Technica, 21 Mar 2024.
- [10] A. Adams, M. A. Sasse. "Users Are Not the Enemy." Communications of the ACM 42(12), 1999, pp. 40–46.
- [11] C. Herley. "So Long, and No Thanks for the Externalities: The Rational Rejection of Security Advice by Users." NSPW 2009, ACM, pp. 133–144.
- [12] A. Whitten, J. D. Tygar. "Why Johnny Can't Encrypt: A Usability Evaluation of PGP 5.0." USENIX Security Symposium 1999.
- [13] K.-P. Yee. "User Interaction Design for Secure Systems." ICICS 2002, LNCS 2513, Springer, pp. 278–290.
- [14] J. H. Saltzer, M. D. Schroeder. "The Protection of Information in Computer Systems." Proceedings of the IEEE 63(9), 1975, pp. 1278–1308.
- [15] J. Nielsen. "Enhancing the Explanatory Power of Usability Heuristics." CHI 1994, ACM, pp. 152–158. Updated as "10 Usability Heuristics for User Interface Design," Nielsen Norman Group.
- [16] L. F. Cranor. "A Framework for Reasoning About the Human in the Loop." UPSEC 2008, USENIX.
- [17] A. Beutement, M. A. Sasse, M. Wonham. "The Compliance Budget: Managing Security Behaviour in Organisations." NSPW 2008, ACM, pp. 47–58.
- [18] G. P. Hancke, M. G. Kuhn. "An RFID Distance Bounding Protocol." SecureComm 2005, IEEE, pp. 67–73.
- [19] A. Francillon, B. Danev, S. Capkun. "Relay Attacks on Passive Keyless Entry and Start Systems in Modern Cars." NDSS 2011, Internet Society.
- [20] L. Francis, G. Hancke, K. Mayes, K. Markantonakis. "Practical NFC Peer-to-Peer Relay Attack Using Mobile Phones." RFIDSec 2010, LNCS 6370, Springer, pp. 35–49.
- [21] K. Krombholz, P. Frühwirth, P. Kieseberg, I. Kapsalis, M. Huber, E. Weippl. "QR Code Security: A Survey of Attacks and Challenges for Usable Security." HAS 2014 (HCI International), LNCS 8533, Springer, pp. 79–90.
- [22] Government of India. The Digital Personal Data Protection Act, 2023 (No. 22 of 2023). Gazette of India, 11 August 2023.
- [23] ISO/IEC 14443-1:2018 to 14443-4:2018. Cards and security devices for personal identification — Contactless proximity objects. International Organization for Standardization.

- [24] ISO/IEC 18092:2023. Information technology — Telecommunications and information exchange between systems — Near Field Communication Interface and Protocol (NFCIP-1).
- [25] ISO/IEC 18004:2024. Information technology — Automatic identification and data capture techniques — QR Code bar code symbology specification.
- [26] ISO/IEC 29100:2024. Information technology — Security techniques — Privacy framework.
- [27] A. Cavoukian. Privacy by Design: The 7 Foundational Principles. Information and Privacy Commissioner of Ontario, 2009 (rev. 2011).
- [28] W3C. Web Content Accessibility Guidelines (WCAG) 2.2. W3C Recommendation, 5 October 2023.
- [29] OWASP Foundation. Application Security Verification Standard (ASVS) 4.0.3, 2021; and OWASP Logging Cheat Sheet.
- [30] A. Shostack. Threat Modeling: Designing for Security. Wiley, 2014.
- [31] R. Anderson. Security Engineering: A Guide to Building Dependable Distributed Systems, 3rd ed. Wiley, 2020. (Ch. 13 "Physical Tamper Resistance", Ch. 16 "Physical Protection".)
- [32] R. Verdult. The (in)security of proprietary cryptography. PhD thesis, Radboud University Nijmegen / KU Leuven, 2015.
- [33] J. Bonneau, C. Herley, P. C. van Oorschot, F. Stajano. "The Quest to Replace Passwords: A Framework for Comparative Evaluation of Web Authentication Schemes." IEEE Symposium on Security and Privacy 2012, pp. 553–567.
- [34] S. Garfinkel, H. R. Lipford. Usable Security: History, Themes, and Challenges. Morgan & Claypool, 2014.
- [35] Apple Inc. "Apple adds support for contactless student ID cards in Wallet." Apple Newsroom, 2 October 2018; and "Apple brings contactless student IDs on iPhone and Apple Watch to more universities," 13 August 2019.
- [36] C. Brocius. "My Arduino can beat up your hotel room lock." Black Hat USA 2012 (Onity HT lock vulnerability).
- [37] D. M'Raihi, S. Machani, M. Pei, J. Rydell. RFC 6238: TOTP: Time-Based One-Time Password Algorithm. IETF, May 2011.
- [38] S. Josefsson, I. Liusvaara. RFC 8032: Edwards-Curve Digital Signature Algorithm (EdDSA). IETF, January 2017.
- [39] E. Rescorla. RFC 8446: The Transport Layer Security (TLS) Protocol Version 1.3. IETF, August 2018.
- [40] M. Jones, J. Bradley, N. Sakimura. RFC 7519: JSON Web Token (JWT). IETF, May 2015.
- [41] NXP Semiconductors. MIFARE DESFire EV3 contactless multi-application IC (product data sheet, AES-128 mutual authentication); MIFARE Plus EV2 product data sheet. NXP, 2020–2022.
- [42] M. A. Sasse, S. Brostoff, D. Weirich. "Transforming the 'Weakest Link' — a Human/Computer Interaction Approach to Usable and Effective Security." BT Technology Journal 19(3), 2001, pp. 122–131.
- [43] IIIT-Delhi. Course Project Guidelines, CSE 347/652 | DES 306/525 Usable Security and Privacy, Monsoon 2026 (Dr. Arun Balaji Buduru). Course handout.

Note on source quality. Sources [8], [9] and [36] are security-conference or vendor disclosures rather than peer-reviewed papers; they are cited for the existence and nature of a publicly demonstrated attack, with the primary disclosure named and a reputable secondary report given. Vendor data sheets [41] are cited only for the cryptographic primitives a product family claims to implement, not for security assurance. Source [35] is cited only for the fact that named universities offer NFC student credentials in Apple Wallet, as stated by Apple; it is not cited as evidence of security properties.